A03 - Software Supply Chain Failures

- **Problem:** Vulnerabilities or compromises in third-party components, development tools, or software build and distribution processes
- **Impact:** Malicious code injection, application compromise, or widespread supply chain attacks

Common vulnerabilities:

- **Vulnerable dependencies:** Outdated, unpatched, or unsupported libraries and frameworks
- **Untrusted components:** Malicious or compromised third-party packages
- **Dependency blind spots:** Untracked direct or transitive dependencies
- **Insecure CI/CD:** Compromised build pipelines, repositories, or developer tools
- **Weak access controls:** Excessive privileges and lack of separation of duties
- **Poor change management:** Untracked changes to code, tools, or dependencies

Preventing Software Supply Chain Failures

- **Track dependencies:** Maintain a Software Bill of Materials (SBOM), including transitive dependencies
- **Monitor vulnerabilities:** Continuously scan components and track CVEs
- **Patch regularly:** Update vulnerable dependencies and development tools
- **Use trusted sources:** Prefer official repositories and signed packages
- **Secure CI/CD:** Enforce MFA, least privilege, code reviews, and separation of duties
- **Ensure integrity:** Sign builds, verify provenance, and protect artifacts
- **Control changes:** Track modifications to repositories, pipelines, and dependencies
- **Limit exposure:** Remove unused components and use staged deployments